

Gym / Salon / Spa DPDPA Starter Checklist

Your gym, salon or spa doesn't just manage appointments — it stores health, body and image data every day. Work through these ten areas to bring customer photos, health/body data, staff access and old-record retention under DPDPA-ready control.

Membership Data

Health Details

Body Measurements

Customer Photos

Photo Consent

WhatsApp Campaigns

Staff Access

Retention

How to use this: tick what you already do, and turn the unticked boxes into your next actions. Start with photo consent, health-data access and staff phones — they remove the most risk for the least effort.

1 Customer & membership data

- ☐ List where customer data is collected — booking app, walk-in form, WhatsApp, Instagram DMs, staff notes.
- ☐ Collect only the membership, contact and appointment data you actually need.
- ☐ Keep one primary record (app/CRM) so you always know what you hold.
- ☐ Capture emergency contacts and family/group details only where needed.
- ☐ Tell customers how their data is used and shared at sign-up.

2 Health & body data

- ☐ Collect fitness goals, weight, BMI, injuries and allergies only when needed.
- ☐ Treat health and body data as high-impact — restrict who can see it.
- ☐ Keep health declarations out of uncontrolled WhatsApp and staff notes.
- ☐ Store body/health data in an access-controlled system, not personal phones.
- ☐ Set a deletion rule for old health and body records.

3 Skin / hair / therapy consultation notes

- ☐ Limit consultation notes to the staff who deliver the service.
- ☐ Avoid storing consultation notes in shared chats or open sheets.
- ☐ Don't reuse consultation/therapy notes for marketing without consent.
- ☐ Review who can read and edit consultation records.
- ☐ Apply a retention rule to old consultation notes.

4 Customer photos & before-after images

- ☐ Get separate, documented consent before using customer photos or videos.
- ☐ Offer a clear removal process for photos and testimonials on request.
- ☐ Don't post before-after or bridal photos without specific consent.
- ☐ Keep customer photos off staff personal phones and personal social media.
- ☐ Store and delete customer images under a defined retention rule.

5 WhatsApp campaigns & appointment reminders

- ☐ Separate promotional messages from transactional appointment reminders.
- ☐ Get opt-in for promotions and offer an easy opt-out.
- ☐ Keep a central record of message preferences and consent.
- ☐ Avoid adding customers to broadcast lists without permission.
- ☐ Don't run campaigns from staff personal WhatsApp accounts.

6 Appointment app / CRM / gym software

- ☐ Consolidate customer data into an app/CRM with role-based access.
- ☐ Limit which staff can view full customer profiles and history.
- ☐ Turn on MFA on app, CRM, email and admin accounts.
- ☐ Confirm what your software vendors store and for how long.
- ☐ Review access at least twice a year.

7 Staff phones & personal WhatsApp

- ☐ Move customer communication to business channels, not personal phones.
- ☐ Don't let staff keep customer photos or notes on personal devices.
- ☐ Prohibit personal WhatsApp for customer follow-up.
- ☐ Brief staff on what they can and can't store or share.
- ☐ Wipe customer data from devices when staff leave.

8 Trainer / therapist / beautician access

- ☐ Give each role only the customer data it needs.
- ☐ Don't share logins across staff, branches or vendors.
- ☐ Remove ex-staff and old vendor/branch access the same day they leave.
- ☐ Keep branch-level systems consistent and access-controlled.
- ☐ Review access for biometric/body-analysis devices and CCTV.

9 Customer record & photo retention

- ☐ Set a retention period for old member records, photos and consultation notes.
- ☐ Don't keep customer data, photos and notes indefinitely for marketing.
- ☐ Schedule a periodic review to archive or delete records past their period.
- ☐ Offer customers a way to request removal of their photos and records.
- ☐ Write retention rules down so the whole team applies them consistently.

10 Wrong-photo sharing & breach response

- ☐ Write a one-page plan: who to call and what to do first if a photo or record reaches the wrong person.
- ☐ Know how to quickly lock a compromised WhatsApp, app or CRM account.
- ☐ Keep a contact list (IT, software vendor, and a way to reach affected customers).
- ☐ Be ready to notify the Data Protection Board and affected customers as required.
- ☐ After any incident, record what happened and what you changed.